

Cloud Forensics

*(thanks and contribution from Marrapodi Francesco -
S332062 – former CFCCA student)*

Cloud forensics peculiarities (I)

■ Brief definition and high level aspects

- Cloud forensics is a new discipline that applies digital forensics techniques to cloud environments
- As cloud adoption rises, incidents like data breaches are becoming more complex and frequent.
- Ad-Hoc methodology to adopt Digital forensics process to cloud environments

■ introduce a set of structural peculiarities that make digital forensics harder than in traditional on-premises contexts

Cloud forensics peculiarities (I)

■ **Multi-tenancy in distributed environment**

- multiple users or organizations share the same physical and virtual resources in a cloud environment
 - an investigator cannot simply image an hard drive because the drive contains other customers' data interleaved with the target's
 - requires help from the cloud provider to ensure compliance with privacy regulations

Cloud forensics peculiarities (II)

■ ephemeral and volatile resources

- Instances (containers, VMs, serverless services) may exist for seconds
- normally, when they terminate, their memory, process tables, and local logs are gone
- auto-scaling changes environment on demand
- log and evidences are ephemeral - may require real-time monitoring
- quick VM snapshot
 - creation of storage volume backups
- needed help from CSP
 - AWS Glacier for long-term storage
 - azure Blob archive

Cloud forensics peculiarities (III)

■ Limited visibility and provider dependency

- Variable depending on the cloud model
 - In IaaS, you own the OS layer upward. In PaaS and SaaS, no access to logs, metadata, network captures, or storage
- no-control over the hardware, thus mediated access to disk images and raw memory acquisition
 - reliance to logical or API-based data access,
 - often based on snapshotting virtual disks or exporting logs instead of physical evidence acquisition
 - use of CSP-provided tools with imposed granularity (e.g. AWS CloudTrail, Microsoft Azure Monitor, Google CloudLogging)
- different possible storage systems (Amazon S3, AWS EBS, Azure files)

Cloud forensics models

■ SaaS

- provider manages the entire infrastructure.
- forensic investigations highly dependent on the cooperation of the service provider
- data may be stored and processed in multiple locations, often unknown to the user.
- forensic investigations are often restricted to user-level logs and application-level records.
- advanced forensic tasks, such as memory analysis or in-depth data reconstruction, may not be feasible without provider support

Cloud forensics models

■ PaaS

- Users manage applications, while the underlying infrastructure and runtime are controlled by the provider.
- more clarity and better control over data sovereignty
- More balanced relationship with the provider
- More robust log analysis and application-level forensics

■ IaaS

- greater control over the entire system, managing virtual machines, storage, and network configurations.
- under a jurisdictional and political point of view, users have more control over where data are stored.
- users can access/manage virtual machines, enabling analysts to perform more comprehensive forensic analyses.
- reliance on the provider for physical hardware

Cloud Storage example of service

■ Amazon S3 (Simple Storage Service)

- objects within buckets (data, metadata, unique identifiers)
- automatically scales to handle increased data storage
 - with high availability for stored data (99,99...%)
 - replication among multiple availability zones
- multiple storage class (standard, smart-tiering, "Glacier", ...)
- event notification and trigger (for PUT, POST, DELETE, ...)
- versioning and object lock
- encryption
 - keys can be provided by Amazon or by the customers
- other provider offers similar solutions (*Google Cloud Storage, Azure Blob Storage, Aruba Cloud Object Storage, ...*)

Cloud Storage example of service

■ S3 storage classes (examples)

■ standard

- default storage class offering high durability, availability, and low latency
- suitable for frequently accessed data (e.g., web applications, content delivery) with low latency (milliseconds)

■ glacier deep archive

- low-cost storage for long-term retention and rare access
- retrieval in terms of hours

■ smart/intelligent tiering

- auto-adjust (frequent-infrequent) based on access pattern
- latency from millisecond to minutes, cost adjustment

Cloud forensics peculiarities (IV)

■ Jurisdictional fragmentation

- cloud data lives wherever the provider has put it
 - may be multiple countries simultaneously due to replication
- patchwork of applicable legal regimes, some of which conflict directly
 - (e.g., EU GDPR data transfer restrictions vs. US CLOUD Act extraterritorial reach)

Cloud forensics peculiarities (V)

■ Log integrity and completeness

- Logs may be incomplete by default
 - e.g., management operations (like modifying an IAM policy, launching an instance, deleting a database – i.e. control plane) are logged by default
 - data-plane events (e.g. reading an S3 object) often require explicit activation – *an attacker may exfiltrate 50GB of sensitive files without notice*
- can be disabled or deleted by a sufficiently privileged attacker
- are typically not cryptographically signed in ways that courts will easily accept (e.g., the signing key is AWS's)
- cloud-native timestamps may differ from wall-clock time in ways that matter for event reconstruction (e.g. VM clock may drift due to overload, and so the applications

Cloud peculiarity effects (I)

■ Lack of physical access

■ identification

- requires collaboration with the CSP to determine logical location and physical data hosting
- requires knowledge of specific cloud tools (e.g. AWS CloudTrail, Azure Monitor) to identify relevant data sources

■ collection

- reliance on API limits control and may introduce delay
- again, knowledge of storage compatible tools (e.g. *AWS CLI*, *Rclone*, ...)
- collaboration with CSP
 - to ensure completeness and timely collection
 - to access access logs, contextual metadata

Cloud peculiarity effects (II)

■ Lack of physical access

■ Acquisition

- impossibility to create physical images
- snapshot acquisition through CSP APIs (and data integrity)

■ Analysis

- Analysis restricted to logical data, potentially missing critical metadata or hardware-specific artifacts
- direct access to the Cloud infrastructure

■ Presentation

- Use CoC documentation and verification to demonstrate authenticity and integrity (without direct access), and corroborate with CSP testimony/affidavits

Cloud peculiarity effects (III)

■ Redundancy

■ identification

■ request/gather replication details

■ from CSP and using capable forensics tools

■ Collection

■ collecting consistent data from multiple redundant copies while avoiding duplication

■ identify and focus on primary copy

"Primary" copy

- most relevant or authoritative version of data for forensic analysis
 - the original or actively used copy from which redundant or backup copies are derived
- identification of primary copy through
 - timestamp analysis
 - the oldest timestamp is often associated with the primary copy
 - often interesting the copy with the latest changes consistent with the incident timeline
 - replication tags
 - Support from tags like "replica" or "secondary"
 - access logs
 - Identify frequent access pattern/interactions

"Primary" copy identification example (AWS S3)

- **list object in a S3 bucket**

- `aws s3api list-objects --bucket <bucket-name>`

- **get metadata**

- `aws s3api head-object --bucket <bucket-name> --key <object-key>`

- **check replication rules**

- `aws s3api get-bucket-replication --bucket <bucket-name>`

- **check access logs**

- e.g. using AWS CloudTrail

-

(<https://docs.aws.amazon.com/cli/latest/reference/s3api/>)

-

Cloud peculiarity effects (IV)

■ Redundancy

■ Acquisition

- account of all copies with no duplication
- interaction with CSP to deduplicate redundant copies
- acquire metadata for any replicas to document consistency

■ Analysis

- analyse all data to ensure no discrepancies
- verify hashes, timestamps and contents across copies, but
- ...focus on the "primary" one

■ Presentation

- Explain redundancy impact (i.e. redundancy pro and cons for evidence preservation and consistency)

Cloud peculiarity effects (V)

■ Virtualisation

■ identification

- identification of specific virtual machines/containers/instances in a shared environments
- instance identifier and hypervisor logs for activity association

■ Collection

- data collection from VMs/containers without maintaining the system live
- Snapshooting (plus VDIs) and associated logs

Cloud peculiarity effects (VI)

■ Virtualisation

■ acquisition

- acquire VM-specific data (e.g., virtual disks, memory) while ensuring data and infrastructure integrity
- export virtual disks (e.g., VMware Virtual Machine Disks (VMDK), QEMU Copy-on-write (QCOW)) and mem snapshots
- collaboration with CSP to reduce impact on the multi-tenant architecture (e.g. for large data acquisition)

■ analysis

- multiple layer of abstraction
- log hypervisors/VM configuration for activity identification
- use of virtualization-aware" forensic tools (EnCase, FTK, ...)

Cloud peculiarity effects (VII)

■ Virtualisation

■ presentation

- explain virtualisation complexities (to non technical audience)
- provide visual aids to describe virtualization concepts
- describe approach/measures taken to preserve and analyse virtual environment

Cloud peculiarity effects (VIII)

■ Volatility

■ identification

- identify volatile data (RAM content, active connections) before lost (due to service dynamics)
- exploit real-time monitoring and logging tools (CSP-provided flow logs)

■ collection

- overwritten/lost data for instance shutdown/recycling
- prioritize collection of volatile data
- Activate/request tools where available
 - Memory dumping/network data stream where possible

Cloud peculiarity effects (IX)

■ Volatility

■ acquisition

- acquire volatile data (e.g., RAM, CPU states) before its state changes
- CSP features to snapshot memory/active connections (and if possible automate for speed)

■ analysis

- incomplete/missing data lead to gaps
- reconstruction using logs and contextual evidence
- cross-correlation of volatile/non-volatile sources

■ Presentation

- describe/justify possible gaps and correlate with other sources to support conclusions

	Techniques	Challenges	IaaS	PaaS	SaaS
Identification	• Locating Resources • Access and Utilization Modes • Data Format and Encoding • Mapping Resources	• Indeterminate Resource Placement • Decentralized Data Storage • Physical Inaccessibility • Data encryption	Forensic investigators access detailed system logs, configurations, and even disk images. Identification typically involves locating virtual resources and gathering metadata to pinpoint evidence.	Identification focuses on logs generated by platform and application, making it crucial to collaborate with the provider for lower-level data access.	Identification relies heavily on user-level logs, access records, and collaboration with the provider to access deeper levels of data.
Collection and Acquisition	• API Usage • Snapshotting • Control Tools • Detection and Response Data • Live Forensics	• provider negotiation for deeper access • Volatile data	use of snapshotting to resolve the "volatility issue" of virtual resources.	Same as IaaS	Data collection is mostly limited to what the provider offers through APIs.
Preservation	• cryptographic hash	• Duplication • Multi-Tenancy • Volatile data	 INVESTIGATION PROCESS IN CLOUD FORENSICS		
Analysis and Presentation	• integrate the different data sources • Timeline Reconstruction • normalize timestamp	• various subsystems • distribution across multiple devices • unsynchronization			

Cloud forensics tools examples

■ FTK Imager

- Allow for acquisition of cloud storage object (like S3 objects)
 - use cloud provider to access required data
 - download to a local folder
 - Import in FTK imager

■ Magnet AXIOM

- obtain valid credentials (e.g., API keys, tokens) to access the cloud resources in a secure and authorized manner
- axiom Cloud can acquire and analyze data from cloud sources when provided with credentials

■ Belkasoft Evidence Center

- acquire/analysis/report evidence from cloud services (Cloud storage services, backups, webmail, social media/messaging)

Cloud forensics tools examples

	AWS CloudTrail	GCP Operations Suite	Azure Monitor
Identification	• Captures detailed API logs for tracking user actions and changes in AWS Environments	• Provides full-stack observability with integrated monitoring, logging, and tracing.	• Offers visibility across Azure and on-premises environments.
Collection and Acquisition	• Centralized logging of API calls across AWS services. • Ensures log integrity validation using cryptographic hashing	• Aggregates logs from various GCP services. • Supports large-scale log collection and querying	• Collects telemetry data from Azure services and hybrid environments. • Enhanced integrity checks for reliable evidence gathering.
Analysis	• Provides granular log analysis for reconstructing attack paths.	• Correlates logs, performance metrics, and traces enabling direct exports to BigQuery.	• Supports detailed querying and data visualization